
ENTERPRISE THIRD-PARTY RISK MANAGEMENT POLICY

POLICY NUMBER:	P 1053.01
VERSION NUMBER:	5.0
POLICY EFFECTIVE DATE:	MARCH 2017
VERSION EFFECTIVE DATE:	OCTOBER 2025
POLICY OWNER:	ENTERPRISE THIRD-PARTY RISK MANAGEMENT
SENIOR MANAGEMENT SPONSOR:	CHIEF ADMINISTRATIVE OFFICER
DATE LAST MODIFIED:	SEPTEMBER 2025
DATE OF MANAGEMENT REVIEW:	OCTOBER 2025
DATE OF NEXT MANAGEMENT REVIEW:	OCTOBER 2026
FHI BOARD APPROVAL REQUIRED:	YES
LEVEL OF BOARD APPROVAL REQUIRED:	BOARD RISK COMMITTEE
DATE OF BOARD REVIEW:	OCTOBER 2025
DATE OF NEXT BOARD REVIEW:	OCTOBER 2026

OVERVIEW

First Hawaiian Inc. and First Hawaiian Bank (FHB or Bank) (collectively known as FHI or the Company) engages third parties to provide goods and perform services, and as such, understands that using a third party does not relieve FHI of its responsibility for ensuring that the third-party activity is performed in an appropriate manner that complies with applicable laws, rules, regulations, and internal policies while minimizing the risk of harm to FHI and its customers. To ensure that FHI is able to fulfill its responsibilities, it is critical that all employees and affiliates comply with FHI's Enterprise Third-Party Risk Management Policy ("Policy").

TABLE OF CONTENTS

1. PURPOSE STATEMENT	3
2. REGULATORY ALIGNMENT	3
3. SCOPE	3
4. POLICY ADMINISTRATION & GOVERNANCE.....	3
5. DEFINITIONS	3
6. ROLES & RESPONSIBILITIES	4
7. POLICY	5
8. EXCEPTIONS.....	7
9. REFERENCES	7
10. REVIEW & REVISION HISTORY	7

1. PURPOSE STATEMENT

Third-party relationships inherently pose risks to FHI such that failure to manage such risks can potentially expose FHI to material risks such as regulatory action, litigation, financial loss and reputation damage. Therefore, it is necessary to implement a comprehensive third-party risk management Policy to identify and manage these risks throughout the relationship.

2. REGULATORY ALIGNMENT

This Policy aligns with the *Interagency Guidance on Third-Party Relationships: Risk Management (88 FR 37920)* and the expectations to establish sound risk management principles for all stages in the life cycle of third-party relationships. As outlined in the *Interagency Guidance*, this program establishes a consistent framework to engage in more comprehensive and rigorous oversight and management of third-party relationships that support higher-risk activities, including critical activities. Furthermore, to ensure the security, transparency, and efficiency of FHI operations, this Policy adheres to the expectations set forth in the *Interagency Guidelines Establishing Information Security Standards (12 C.F.R. Part 364, Appendix B)* and the *Bank Services Company Act (BSCA) (FDIC Letter 1999-06)*, including the requirement for FHI to notify its primary regulator within 30 days of establishing a service contract or initiating services with a bank service company.

3. SCOPE

All FHI employees, contractors, part-time and temporary workers, and those employed by others to perform work on behalf of FHI or who have been granted access to FHI information or systems, whether on or off FHI premises, must comply with this standard and applicable procedures.

4. POLICY ADMINISTRATION & GOVERNANCE

4.1. ORGANIZATIONAL STRUCTURE

The Board Risk Committee (BRC) is responsible for the oversight of this Policy, with the Senior Management Sponsor being accountable for its implementation.

4.2. REVIEW

At least annually, the Policy Owner will review this Policy and recommend appropriate changes, if necessary, for approval. The review will include consideration of applicable law, feedback on the effectiveness of the Policy, and any input from supervisory entities and oversight partners.

4.3. POLICY APPROVAL

This Policy was approved by the BRC at inception, and thereafter upon annual renewal and whenever any material changes are proposed. Updates to the Policy will be provided to the Technology, Cybersecurity, and Data Management Committee (TCD) for their review.

5. DEFINITIONS

5.1. “**Product**” means any goods or services that a Third Party provides to, or on behalf of, FHI.

- 5.2. **“Third Party”** refers to any entity that has entered into a business relationship with FHI, whether the third party is a bank or a nonbank, affiliated or not affiliated, regulated or nonregulated, or domestic or foreign; this includes vendors as well as non-vendors.
- 5.3. **“Vendor”** refers to any third party with a direct business arrangement with FHI, such as providers selling products to FHI.
- 5.4. **“Non-Vendor Third Party”** refers to any third party that provides products to our customers rather than to FHI, but still involve a direct relationship with FHI.
- 5.5. **“Third-Party Risk”** refers to the level of potential risk that arises from FHI relying on outside parties to perform services or activities on their behalf.
- 5.6. **“Third-Party Criticality”** refers to the criticality rating inherited from the related business process – See reference to Business Continuity Management Policy (P 1797.00).
- 5.7. **“Critical Subcontractors”**: subcontractors are 4th parties that an FHI third party depends on to deliver the Product/Service to FHI. A critical subcontractor provides a Product/Service to FHI’s third parties where the subcontractors unavailability would materially disrupt FHI.
- 5.8. **“Bank Service”**, as defined by the BSCA, refers to:
- Check and deposit sorting and posting (including online banking),
 - Computation and posting of interest and other credits and charges,
 - Preparation and mailing of checks, statements, notices, and similar items (including electronic statement delivery),
 - Any other clerical, bookkeeping, accounting statistical, other similar functions such as data processing, internet banking, or mobile banking services performed for a depository institution.

6. ROLES & RESPONSIBILITIES

Role	Responsibilities
Third-Party Manager (TPM)	FHI Third-Party Managers (TPMs) are responsible for complying with the ETRM Policy, Standard, and Procedures. The TPM designated as the individual responsible for managing the third-party relationship and associated engagements for the FHI business unit must be Officer level or above. TPMs are responsible for all steps in the third-party risk management life cycle; due diligence, contract negotiation (where applicable), ongoing monitoring, and termination. The TPM may delegate responsibility for satisfying due diligence requirements, but is ultimately accountable for compliance with the Policy, Standard, and Procedures. TPMs serve as the primary contact person within the BU for questions about the third party and product owned by that BU as well as the BU’s compliance with this Policy. The TPM must promptly report all relevant personnel changes to ETRM, and any other department as otherwise required. Where multiple BUs use the same third party, unless otherwise agreed among the BUs, the BU with the contract with the third party will own the relationship. If multiple BUs have contracts for the same or different product/services, the BU with the highest risk rating should own the third-party relationship. If the risk rating is the same,

	then the BU with the highest annual spend should own the third-party relationship. BUs using the same third party should coordinate, to the extent possible, risk assessment, due diligence contracting, ongoing monitoring and termination of the relationship with such other BUs.
Enterprise Third-party Risk Management (ETRM) Team	The ETRM Team is responsible for the execution of the Enterprise Third-Party Risk Management Program and oversight over BU compliance with the Policy and Procedures. The ETRM Team is responsible for the following: • Assist and monitor business units on compliance to the ETRM Policy, and Procedures. • Provide quarterly reporting on third-party risk to the BRC and TCD. • Provide training regarding the ETRM Program annually to TPMs and designated individuals responsible for maintaining third-party information in the ETRM System of Record. • Manage internal communications with the TPMs and Reviewers as needed. • Update and maintain the ETRM Policy and Procedures.
Reviewers	Reviewers are Subject Matter Experts (SMEs) assisting TPMs in assessing and onboarding third parties. Each reviewer group (i.e., Vendor Security Review Team, Cyber Architecture Team, Corporate Compliance Division, Legal, Credit Team, and Insurance Manger) may perform their own assessment and/or require certain documentation be provided by the third party based on their assessment. Should consultation or review be required, requests should be made in advance of contract execution or other project deadlines to allow a reasonable time for any reviews and approvals. SMEs with risk ratings (i.e., Compliance, Cyber Architecture, VSR, and Credit/Finance) must have their method/criteria used to assess and assign risk defined, along with defined Service Level Agreement (SLA) to complete reviews, within one year of publication of this policy.

7. POLICY

7.1. POLICY STATEMENT

FHI's business units ("BU", "BUs") maintain third-party risk management oversight responsibilities through compliance to the Policy and the ETRM Procedures (SP 1053.00). The depth of oversight will be commensurate to the level of third-party risk present and the effectiveness of the controls implemented. Business units will have the requisite elements of a sound third-party risk management strategy to reduce or mitigate third-party risk. On a regular cadence using a risk-based approach (Critical/High Risk: Annually, Medium Risk: Bi-Annually, Low Risk: Tri-Annually), the ETRM team will monitor third-party risk management activities to ensure business units are complying to the Policy and Procedures.

7.2. DUE DILIGENCE

At the onset of a third-party lifecycle, business units must determine whether the third-party relationship meets the overall strategic goals, objectives, risk appetite, risk profile, and broader FHI policies. Once a third party is determined, BUs must identify and assign an officer of FHI as the third-party manager responsible for managing, mitigating, and overseeing the third-party relationship.

Business units will complete an inherent risk assessment in the ETRM system of record which considers potential third-party risks across multiple risk areas (i.e., Technology Risk, Security Risk, Compliance Risk, and Financial Viability Risk). The inherent risk rating will provide an indication of third-party risk involved prior to any efforts to reduce or mitigate the risk as a rating of *High*, *Medium*, *Low*, or *Minimal*.

Business units and/or risk teams conduct a residual risk assessment in the ETRM system of record based on the criticality and other factors to determine the reduction or mitigation of the inherent risk for the third party. The outcome of the residual risk assessment will be a residual risk rating of High, Medium, or Low. The residual risk rating will help guide FHI in determining the remaining risk for any given third-party relationship after due diligence and/or controls have been implemented.

Third-Party Managers assigned by the business unit will work with various reviewing teams across FHI to reduce or mitigate inherent risks. Each of these teams may perform their own risk assessments and/or require certain deliverables be provided by the third party based on their assessments. Based on the criticality and risks identified, some of these deliverables may include third-party contracts, certificate of insurance, policies, financials, business continuity and disaster recovery plans, etc. FHI will not do business with any third party found to be on the Office of Foreign Assets Control (OFAC) list or under sanction due to a violation of the Bank Secrecy Act.

7.3. CONTRACT NEGOTIATIONS

When third-party relationships necessitate contracts, BUs will work with third parties and FHI Legal team to negotiate applicable contracts and include certain clauses to ensure FHI is protected against the risks associated with these relationships. Typically, a Master Service Agreement is created which contains clauses to help mitigate the third-party risk for FHI; however, in some cases these clauses may be located in a Statement of Work or other legal document. When contracts are renewed, third-party risk is re-assessed to determine any potential risks which are then evaluated when renegotiating contracts.

7.4. ONGOING MONITORING

After a third party is onboarded, ongoing monitoring will be performed on a risk-based approach for High, Medium, and Low risk third parties. The extent of the monitoring applied will be based on the criticality and inherent risk rating associated with the relationship. Changes to the risk profile of the third party or any of the engagements with the third party will require the BUs to re-assess the third-party risk and potentially require additional due diligence. Third-party criticality is determined based on the criticality of the business processes associated with each third party.

7.5. TERMINATION

Business units should carefully review the contract prior to termination, follow all contractually mandated procedures and provide all required notifications to mitigate any risk. BUs are responsible for working with legal to terminate a third-party relationship. Based on the size and complexity of the relationship, a final third-party termination questionnaire may be requested of the BUs to ensure all required steps have been taken to

properly terminate the relationship. BUs are responsible to ensure FHB data stored on third-party systems is properly migrated and destroyed in a manner that would prevent unauthorized disclosure of information.

8. EXCEPTIONS

All employees are responsible for identifying situations that would result in an exception to this Policy or any applicable laws and regulations. Those exceptions should be reported promptly, documented, reviewed, and approved at a level of the organization that is commensurate with their determined materiality. In case of doubt, employees should refer to the owner of this Policy and IT Governance for guidance, including whether further escalation and risk acceptance (i.e., IT Governance Exceptions Tracking or Technology Variance) is appropriate.

Failure to report exceptions or comply with this Policy and associated procedures can result in disciplinary actions up to and including termination of employment for employees or termination of contracts for contractors, partners, consultants, and other entities. Legal actions also may be taken for violations of applicable regulations and laws.

9. REFERENCES

9.1. RELATED REGULATORY GUIDANCE

- Interagency Guidance on Third-Party Relationships: Risk Management (88 FR 37920)
- Service Providers (CFPB Bulletin 2016-02)
- Interagency Guidelines Establishing Information Security Standards (12 C.F.R. Part 364, Appendix B)
- Bank Services Company Act (FDIC Letter 1999-06)

9.2. RELATED FHI POLICIES AND PROCEDURES

- Enterprise Third-Party Risk Management Standard Procedure, ([SP 1053.00](#))
- Enterprise Risk Management Policy ([FHI-001-RMG; P 3218.00](#)) – See details regarding the FHI Risk Taxonomy, Risk Materiality Framework (RMF) and what is deemed a material risk (i.e., a risk with a residual score of “Highly Material” or “Material” based on the RMF).
- Business Continuity Management (BCM) Policy ([P 1797.00](#)) and Standard ([S 1797.01](#)) – Business continuity and disaster recovery for the Bank are governed by the BCM Policy. Where *Critical* business processes are dependent on a third party, the business process will determine the criticality for the third-party relationship.
- BSA Division OFAC Compliance Program (BSA Home [Page](#)).
- Data Categorization Standard ([S 1051.19](#)).

10. REVIEW & REVISION HISTORY

<i>Date</i>	<i>Type of Change: Material or Administrative</i>	<i>Comments</i>
March 2017	Material	New Policy
March 2021	Material	Revised Policy

January 2023	Material	Revised Policy to include Third-Party Risk Management
March 2023	Administrative	Annual review of Policy
April 2024	Material	- Renamed to Enterprise Third-party Risk Management Policy, replaced the term vendor with third-party throughout the document. - Combined “Vendor Risk Management” and “Third-party Risk Management” sections into one simplified section called “Policy Statement”. - Removed “Potential Risks” section and replaced with reference to Risk Taxonomy (FHI-002-RMG; P 3220.00). - Removed “Governance” section as this content is already covered in the “Overview” section. - Consolidated regulatory guidance into FFIEC and Interagency Guidance, which summarize the regulatory requirements for third-party risk management. - Added ETRM purpose and objectives within each phase of the life cycle.
September 2025	Material	- Converted to standard ETM Policy template. - Updates to “Definitions”. - Updates to “References” (added BSA Program, Data Categorization Standard and removed FFIEC guidance that was superseded by Interagency Guidance). - Added “Policy Administration and Governance” to align with standard ETM Policy template. - Added new requirement for Risk Reviewers with risk ratings (i.e., Compliance, Technology, Security, and Financial Viability) are expected to have documented procedures in place.